Available online at www.sciencedirect.com

ScienceDirect

IFAC PapersOnLine 52-13 (2019) 928–933

A Clustering Method of Asset Cybersecurity Classification

Vitaly G. Promyslov*,
Kirill V. Semenkov*,
Alexander S. Shumov*

**V.A. Trapeznikov Institute of Control Sciences, Russian Academy of Science, 65 Profsoyuznaya, Moscow 117997, Russia (Tel: +7-495-334-25-22; e-mail: v1925@mail.ru)*

Abstract: A formal method for asset classifying by cyber security is provided. The problem is solved in the frame of a clustering problem. The data structure and content are specified. A classification algorithm for systems with arbitrary number of subsystems is provided.

© 2019, IFAC (International Federation of Automatic Control) Hosting by Elsevier Ltd. All rights reserved.

Keywords: cyber security, formal methods, asset classification, clustering, "take-grant" model, hierarchical systems.

1. INTRODUCTION

The security of the society and the state depends significantly on the security of the backbone infrastructure facilities including (IEC, 2016) nuclear power plants (NPP). The problem of securing I&C (instrumentation and control) systems of NPPs is overall and related to industrial (energy, nuclear and radiological, functional) safety precautions. The safe and efficient operation of modern NPPs is ensured by digital control systems that require appropriate protection against unauthorized actions, for example, against computer attacks, which belongs to the area of information and cyber security (see e.g. Mengazetdinov et al. (2005)).

The solution of the problem of cyber security ensuring is closely related to the tasks of finding critical assets in the protected system and assigning the protection measures to these assets as required by IEC 62645 (2014).

To solve the problems it is necessary to answer some questions.

1. Which protection measures should be assigned to the critical assets to ensure the safety of the whole object?

2. How to make the protection efficient, minimizing the set of applied protection measures for the assets?

3. How to estimate a degree of vulnerability for any asset?

These questions are the crucial ones in the problem of cyber security. They are addressed in a number of documents and research papers. Among the complex papers we may mention the ones developed by the International Electrotechnical Commission (IEC) and the International Atomic Energy Agency (IAEA) (see IAIA 2011, IEC 2014, 2016), ISO/IEC 27000 standard family, papers by Promyslov and Poletykin (2016) and Harchenko et al. (2013) in regard to common principles of ensuring the security of digital control systems.

The following practice for ensuring the security of complex computer-based systems has been established: to build the security architecture using principles of graded approach and defense in depth, when the cyber security levels are assigned to the assets in conformity with the criticality of the asset for the general security (IEC, 2016; FSTEK Russia, 2014) basing on risk assessment. The protection degree for every asset must conform to the assigned level of cyber security. The suitable barriers must be installed between the classified assets. Every asset must be associated with a number of measures aimed to prevent cyberattacks, to reveal them and to react to them (IEC, 2014).

However, the practice has drawbacks: the classification of the assets is subjective, since these days the issues are resolved at the expert level. The weakness of the approach is evident: the result depends on the experts' qualification; the results of the analysis made by different expert groups are difficult to compare.

The professionals are aware of the drawbacks; there were attempts to formalize the problem of asset classifying: see, for example, papers by Promyslov and Poletykin (2012) and Harchenko et al. (2013). But currently there is no comprehensive approach that could formalize the problem of asset classification in a control system, took into account the nature of control systems and using top-to-low principles.

We propose considering the classification problem as a clustering problem (see, e.g., the introduction to the cluster analysis in the book by Kaufman and Rousseeuw (1990)). Under this approach the asset classification problem may be formalized as a problem of data structuring, that is, identifying groups of objects to which the equal selection criteria could be applied.

The presented method takes to the complete account the established practice of cyber security assets classifying stated in the field-specific papers of IAEA and IEC.

2405-8963 © 2019, IFAC (International Federation of Automatic Control) Hosting by Elsevier Ltd. All rights reserved.
Peer review under responsibility of International Federation of Automatic Control.
10.1016/j.ifacol.2019.11.313

2. CLUSTERING IN THE CLASSIFICATION PROBLEM

The cluster analysis considers a cluster as a part of the data, typically, a subset of objects which are characterized by a subset of variables, separated from the set by some uniformity of elements.

The clustering problem can be divided into four sub-problems:

1. Choice of the input data representation for the analysis;

2. Determination of the clustering structure shape;

3. Choice of the estimation criterion of the clustering structure;

4. Choice of the procedure for the construction of the clustering structure.

Onward we will consider each of the sub-problems in the context of asset classifying by cyber security.

2.1 Input data types and the choice of data representation for the analysis

Assets must be identified, the attribute values and measurement scales must be determined for the choice of the data representation. We propose to use the "asset–attribute" table to specify the relations between attributes and assets.

We suggest considering the following attributes:

1. Nuclear safety (NS) class of the object to which the asset belongs. A number of classification systems have been developed in the nuclear industry associating the systems or the performed functions with their impact on the nuclear safety (see for example (GAN Russia 1997) or (IEC 2009). Nuclear safety class of a system is unequivocally related to the damage of the system failure.

2. Functional properties of the asset (an asset is considered as a "gray box" having some internal properties).

3. Asset security informational properties: the attributes presenting information link of an asset with the other assets.

The number of attributes can be arbitrary but in the paper we've limited ourselves to three attributes.

Data representation may use any of the three common kinds of scales: rank scale (dealing with ranks), quantitative scale (applied to measurable properties), and nominal scale (applied to qualitative properties).

2.2 The attribute "NS class"

The ranking attribute determines the belonging of an asset to the system classified according to the nuclear safety. The rank scale is reduced to a quantitative one with the ordering function $R_1(x) = \{1, 2, 3\}$ (for the 1st, 2nd and 3rd safety classes respectively).

2.3 The attribute "Asset functional property"

Any properties that are relevant for the cyber security can become the asset functional properties. For example: control functions, diagnostics and monitoring function, and auxiliary functions.

We reduce the nominal property to a qualitative kind with the ordering function $R_2(x) = \{1, 2, 3\}$ respectively.

2.4 The attribute "Asset security informational properties"

Asset cyber security informational properties are mostly determined by the levels of confidentiality, integrity and availability. We will stick to the definitions of standard ISO/IEC 27000 (ISO 2018a) where the confidentiality is referred to as property that information is not made available or disclosed to unauthorized individuals, entities, or processes; the integrity is the property of accuracy and completeness; and the availability is the property of being accessible and usable. The classical approach for their estimation is using expert ranking technique bringing them to fixed levels (ISO 2018b). We propose an analytical way to quantify the attribute.

Let the security properties of an asset x in a system S is characteristic depending on three parameters, i.e. $S(x) = S(C(x), I(x), A(x))$, where the parameters are: C – confidentiality, I – integrity, A – availability.

In practice, the availability A is a free parameter depending on time t while C and I vary with time slowly and mainly depend on the system structure. Our simplified model supposes $A = A(t)$ is a function of time only while $C = C(x)$ and $I = I(x)$ are the functions of asset properties only. We will neglect the time-dependence, and this is a reasonable assumption for the top-level analysis of the cyber security architecture of a system when the dynamical behavior of the system is, in fact, ignored. So the cyber security can be written as $S = S(C, I, A),\ A = const$.

It is admissible to assume in informational security that the integrity and confidentiality are not independent parameters (compare Bell and La Padula (1973) and Biba (1975) models) but they can be expressed through each other. We will consider the integrity only because I&C systems focus on the securing of integrity (see IEC 2014).

2.5 Security graph and take-grant model

Let us introduce the system model as a graph (security graph) reflecting the real (physical) matter of the described I&C system. The properties of a graph of that sort are shown in Table 1. Let denote a security graph as $G = G(X, E)$ where X is the set of vertices, E is the set of arcs.

Table 1. The correspondence between real properties of the modeled system and its representation as a graph

A physical property of the system	**Graph *G (X, E)* property**
An action has the source and the end	Directedness
There are different kinds of security assets (active and passive ones)	The vertices can belong to different types
There are different kinds of relations between the assets (i.e. reading and writing)	The arcs can belong to different types
There is a hierarchy (at least, in some subsystems)	There is an order relation (at least on a subset of vertices $\hat{X} \subset X \in G(X,E)$
The presence of system elements that do not exchange information with each other	The graph is not a total one (a graph is referred to as a total one if for any pair of vertices an order relation is specified. Real systems can contain elements that are not connected with each other)
The presence of barriers (gateways, firewalls, data diodes) in the system	The graph is not transitive, that is, the existence of an order $x_1 \leq x_2$ does not mean that vertices are connected with an arc$(x_1, x_2) \in E$
The reality of engineer facilities	The graph is finite
Dualism, symmetry of relations (i.e. read and write relations)	The graph may contain cycles

We will work with the discrete model of rule propagation also knows as the "take-grant" model (see, e.g., Bishop 2003). The variant of the "take-grant" model considered in this paper is based on the approach described in Promyslov & Poletykin (2012). In the model the security graph *G* is a finite, labeled, directed, weighted multigraph describing the system properties.

Two types of vertices are distinguished in the graph: the first one corresponds to subjects, the second one corresponds to objects. An arc directed from the vertex *A* to the vertex *B* shows that *A* has a right (or rights) on *B*. Normally the following rights are considered as standard ones: read (r), write (w) (with regard to information transfer), take (t), grant (g) (with regard to right transfer). To describe information transfer the model introduces a number of atomic transformations (*Post, Pass, Spy, Find)* as well as graph modifications, adding and removing vertices and arcs *(Create, Delete*).

The initial security graph G_0 can be transformed to a new graph G' by successive applications of the elementary rules. The system cybersecurity is considered in the context of the possibility that a subject can obtain access rights to a certain object (initially the subject does not have the rights) after a co-operation of subjects by the execution of elementary commands. The situations of authorized (i.e. "legal") access rights obtaining as well as "stealing" the rights are considered.

The papers by Promyslov and Poletykin (2012) and Bishop (2003) state the conditions under which a subject can get access $e \in \{r, w, t, \}$ to an asset with the aforementioned set of the access rights and elementary rules of the graph transformation.

As stated above there is no need to estimate both integrity and confidentiality. It is enough to evaluate just one parameter and use an appropriate model describing their dependence, that is, there is an isomorphism: $(X, E\} \leftrightarrow G'(X, \hat{E})$, where E and $\hat{E}$ are the sets of access relation arcs.

Having this in mind, we may propose Table 2 as an example of "asset–attribute" table:

Table 2. Attributes of the I&C NPP assets with reduced information properties division

Asset	Nuclear safety classes (NS)	Asset functional property	Asset informational properties
			Confidentiality/Integrity

2.6 Order relation on a security graph

From the existence of an order relation on a subset of vertices, it follows we can introduce an order function $R(x)$ on this subset. We are going to use the following vertex order function for a security graph: the number of outbound arcs after the transitive closure of the security graph on a selected access relation. It corresponds to the fact that *we consider the system entity passing information to a greater number of peers as more important in terms of defense construction*. The values of asset order function will be used as a quantitative characteristic of asset informational properties: $S_1(C(I), I) \sim R_3(x)$. The approach resembles the usage of cyclomatic complexity metric in software "reliability" estimation where the most critical software module is the one with the maximal cyclomatic complexity (Harrison, 1984).

2.7 Data renormalization

After the quantification of all properties every asset will correspond to a vector of order functions assigning a numerical value of a property for the asset $\{R_1(x), \ldots, R_n(x)\}$, where n is an asset number from the table of attributes.

Table 2 contains data with independent columns; the values of different properties are, although given in numerical form, incompatible. To reduce the properties to a compatible form the renormalization of values is to be performed — the point of reference and the scale are to be changed:

$$R'_{iv}(x) = (R_{iv}(x) - a_v)/b_v. \quad (1)$$

In (1), $R_{iv}(x)$ is the initial matrix of data, $R_{iv}(x)$ is renormalized one, i – assets, v – attributes. The parameter a_v designates the shift of the reference point, and b_v is the new scale for every attribute v. For the purposes of analysis (including cluster analysis) it is better to place the origin somewhere in the center of the set of points representing a property for assets (see for example Mirkin (1996)). As for the scaling factors, they should be chosen on the base of the idea of levelling of attribute relative scales.

2.8 Criteria and clustering method

We suggest using the k-means clustering method of a partition with centroids as described in Bishop (1995). The method is based on the intuitive criterion that objects within the same cluster must be close to each other whereas the objects within different clusters must be far from each other.

The proximity criterion for the table "object–property" is stated as the minimum of the sum of distances between the objects and the centers of corresponding clusters. Consider the normalized matrix obtained from the Table "object–property": $y_{iv} = R'_{iv}(x)$), where the columns $v = 1, \dots, V$ correspond to properties and the rows i correspond to assets. Clustered structure of k-means method is defined with the partition of the object set S into K non-overlapping clusters $S = \{S_1, S_2, \dots, S_K\}$, with the respective centroids $c = \{c_1, c_2, \dots, c_K\}$:

$$W(S, c) = \sum_{k=1}^{K} \sum_{y_i \in S_k} d(y_i, c_k). \quad (2)$$

In (2), $d(y_i, c_k)$ is the square of Euclidean distance.

3. AN EXAMPLE OF CLUSTER ANALYSIS AND THE VERIFICATION OF THE RESULTS

Consider, as an example, a segment of I&C NPP containing eight assets (a-a8). The system attributes are put together into the table of attributes 3. The security graph showing informational links in the frame of take-grant model is presented in Fig. 1.

Table 3. The table of attributes

Asset	Safety class	Functionality	Integrity value
a1	1	1	7
a2	2	1	5
a3	2	1	5
a4	3	3	4
a5	3	2	4
a6	3	2	4
a7	3	3	4
a8	4	2	4

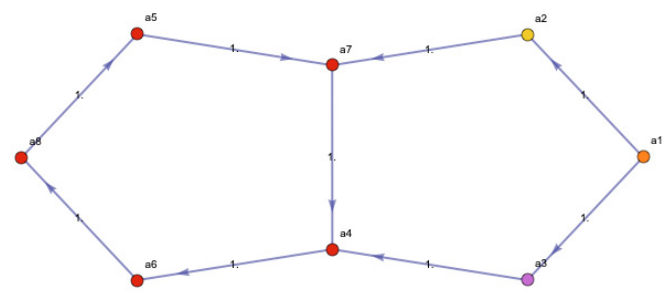

Fig. 1. Security graph for the "take-grant" model.

Let us determine the security levels for the system assets by the relation w using "take-grant" model. To do this, make the transitive closure of the graph by the relation w. The results of the transitive closure are shown in Fig. 2.

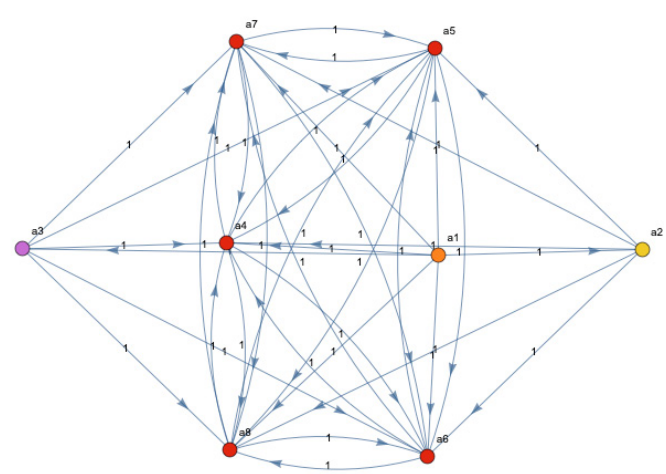

Fig. 2. Transitive closure of the security graph by the relation w.

The partition of the asset set into five non-overlapping subsets was obtained by means of clustering technique, and the assets are aggregated by the proximity of attributes. A graphical representation of the partitioning is shown in Fig. 3 where the axes are the scales of the respective space of attributes.

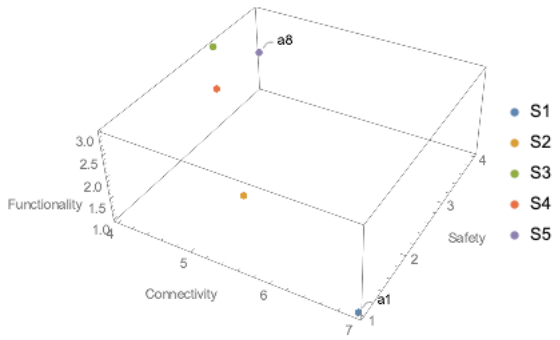

Fig. 3. Asset partitioning by security levels.

The clustering does not solve the problem of asset classifying completely at this stage because the clustering method does not assume an ordering of obtained clusters. To get an ordered cluster set we used the following trick: one asset was attributed to every cyber security level before the clustering, and then these attributed assets were used as centroids of the corresponding clusters. The result was a set of ordered clusters, that is, the sought partition of assets into cyber security levels (see Table 4).

Table 4. Partitioning of assets C into cyber security levels

	Security level				
	S1	**S2**	**S3**	**S4**	**S5**
Asset	a1	a2, a3	a4, a7	a5, a6	a8

4. DISCUSSION

The example deals with one level in NPP I&C hierarchy. But in the real life one-level systems of that sort are rather an exception. If the system of interest has no subsystems (the assets are atomic) then the provided method gives a complete formal approach to the cyber security asset classifying. In case of hierarchical systems we may use inductive techniques.

The structure of the subsystems is not developed yet at the design stage, but the set of subsystems and information flows between them are already known. So one can build the security graph with the subsystems as assets and apply the presented formal method to classify the subsystems on cyber security levels. After that every subsystem is referred to a cyber security class.

But the developers of a *subsystem* face some questions. If a cyber security class is assigned to the subsystem does it mean the all the elements of the subsystem must be protected with respect to this class? For example, if a subsystem with high requirements contains an auxiliary element that has little influence on the system's functions should the element be protected in the same way as the main elements of the system?

Let us consider two security graphs: the first one, $G(X,E)$, takes into consideration the structure of subsystems and the second one, $J(Y,H)$, does not (see Fig. 4). J is evidently a result of graph contraction G: $J = \mathbb{F}(G)$ that is not a one-to-one mapping. The formal classification method generally gives different results on the graphs $J(Y,H)$ and $G(X,E)$. Moreover, since the order function is constructed on the transitive closure of the security graph it leads to a paradoxical conclusion: a developer of a subsystem must know the structure of the whole system and the information flows in the system. As we see, the direct implication of the formal classification method to the full, unfolded graph does not give any practical results.

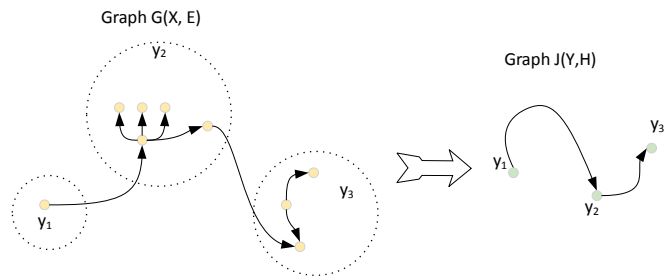

Fig. 4. Security graphs with subsystem structure (left) and without it.

We may eliminate the paradox if note that after the classifying of the subsystems of the graph $J(Y,H)$ into cyber security levels we put an additional constraint onto the subsystem elements in the initial graph $G(X,E)$: we limited the maximal cyber security level for the internal assets of subsystems.

We propose using the following algorithm for the classification of systems with arbitrary number of nesting levels:

1. The system designer considers the security graph with subsystems as vertices and carries out the asset classification for this graph. Then every subsystem gets a cyber security class.

2. The designers of subsystems construct security graphs for their subsystems and classify the assets with additional constraints: maximal cyber security level of an asset equals to the subsystem cyber security level. It is necessary for the correctness that at least one asset in the subsystem has the maximal cyber security level assigned to the subsystem. This asset is to be used as a centroid of the corresponding cluster during the clustering.

3. The designer of 2nd level subsystem (a subsystem inside another subsystem) classifies its assets according to the clause 2 etc.

5. CONCLUSIONS

The paper proposes a formal method for the asset classification by cyber security. The principal stages of the classifying with application to I&C NPP are presented:

1. Asset identification.

2. Nuclear safety class assignment to every asset.

3. Identification of functional attributes and their quantifying.

4. Construction of security graph.

5. Transitive closure of the security graph on the analyzed relation and determination of the order function on the closure.

6. Filling the table “asset–attribute” and data renormalization.

7. Asset clustering in multi-dimensional space of attributes.

8. Classifying of obtained clusters.

The problem of hierarchical system classifying is discussed and the applicability of inductive approach is shown.

The main cluster analysis issue in our case is the absence of strict mathematical relation between clustering results and the sought cyber security levels of the assets. So the result verification is required: either by analysis of inner properties of the classifying results, or by comparison of the results obtained by clustering methods with the results obtained by other proved methods and approaches.

REFERENCES

Bell, D.E. and La L.J. Padula (1973). Secure Computer System: Mathematical Foundations, *MITRE Technical Report MTR-2547. vol. 1*, MITRE Corporation, Bedford, Mass.

Biba, K.J. (1975). Integrity Considerations for Secure Computer Systems, *MITRE Technical Report MTR-3153*, MITRE Corporation, Bedford, Mass.

Bishop, M. (2003). *Computer Security: Art and Science.* Addison Wesley, Boston.

Bishop, C.M. (1995). *Neural Networks for Pattern Recognition.* Oxford University Press, Oxford, England.

FSTEK Russia (2014). Order No 31. (in Russian) *https://fstec.ru/index?id=868:prikaz-fstek-rossii-ot-14-marta-2014-g-n-31*

GAN Russia. (1997). General Regulations of Organization of Safety in Nuclear Power Plants. (in Russian). *http://www.gosnadzor.ru/activity/control/acts/nuclear/7654290.doc*

Harchenko, V., Sklyar. V., and E. Brezhnev (2013). *The Security of Information and Control Systems and Infrastructures*, Palmarinum Academic Publishing. (in Russian)

Harrison, W. (1984). Applying Mccabe's complexity measure to multiple-exit programs. *Software Practice and Experience*, vol. 14, no. 10, pp. 1004-1007.

IAIA (2011). Computer Security at Nuclear Facilities. Technical Guidance Reference Manual. *IAEA Nuclear Security Series*, No 17.

IEC (2009). IEC 61226. Nuclear Power Plants - Instrumentation and Control Important to Safety - Classification of Instrumentation and Control Functions. *https://webstore.iec.ch/publication/4941*

IEC (2014). IEC 62645:2014 ed. 1. Nuclear Power Plants - Instrumentation and Control Systems – Requirements for Security Programmes for Computer-based Systems. *https://webstore.iec.ch/publication/7311*

IEC (2016). IEC 62859:2016. Nuclear power plants - Instrumentation and Control Systems - Requirements for Coordinating Safety and Cybersecurity. *https://webstore.iec.ch/publication/26131*

ISO (2018a). ISO/IEC 27000 Information Technology - Security Techniques - Information Security. *https://www.iso.org/standard/73906.html*

ISO (2018b). ISO/IEC 27005 Information Technology - Security Techniques - Information Security Risk Management. *https://www.iso.org/standard/75281.html*

Kaufman, L., and P.J. Rousseeuw (1990). *Finding Groups in Data: An Introduction to Cluster Analysis.* Wiley, New York.

Mengazetdinov, N.E., Poletykin, A.G., and V.G. Promyslov (2005). Concept of Unauthorized Access Protection Procurement for I&C of NPP “Busher-1” (in Russian). *Automation in Industry*, no. 5, pp. 3-5.

Mirkin, B. (1996). *Mathematical Classification and Clustering*, Kluwer Academic Publishers, Dordrecht-Boston-London.

Promyslov, V.G. and A.G. Poletykin (2012). Formal Hierarchical Security Model of I&C Upper Level System of a Nuclear Power Plant, *Nuclear Measurement and Information Technologies*, no. 4 (44), pp. 39-53. (in Russian)

Promyslov, V.G. and A.G. Poletykin (2016). Approaches to Cyber Threat Counterstand in I&C of a Modern Plant, *Information Security*, no 1, pp. 14-16. (in Russian)